

RELATÓRIO TÉCNICO DE SEGURANÇA

Postura de Segurança — GovCorp

Plataforma de Gestão de Conselhos | INEPAD Consultoria

DATA	VERSÃO	STATUS	VULNERABILIDADES ABERTAS
10/06/2026	1.1 — Onboarding de clientes	Auditoria concluída	0

SUMÁRIO EXECUTIVO

O GovCorp é uma plataforma SaaS multi-tenant para gestão do ciclo completo de reuniões de Conselhos Deliberativos e Consultivos. Este relatório documenta os controles de segurança implementados e o resultado da auditoria técnica conduzida antes do início dos testes com clientes parceiros.

Todos os itens críticos e médios identificados foram corrigidos. O sistema não possui vulnerabilidades conhecidas em aberto na data deste relatório.

1. CONTROLE DE ACESSO E IDENTIDADE

Mecanismo	Implementação
Autenticação	Supabase Auth nativo — JWT assinado pelo servidor com expiração de 1 hora
Autorização	Role lida do JWT (user_metadata) — não editável pelo usuário final
Isolamento multi-tenant	client_id enforcado por Row Level Security em todas as tabelas
Cadastro de usuários	Exclusivamente via Edge Function autenticada — sem auto-registro público
Força de senha	Mínimo 8 caracteres com letras e números (enforcado em Auth e frontend)
Registro público	Desabilitado em produção e homologação

2. ROW LEVEL SECURITY (RLS)

Todas as tabelas possuem RLS ativa. Nenhuma policy utiliza a role *public*. Todos os checks de papel leem do JWT — não da tabela `members` — eliminando vetores de escalada de privilégios via manipulação de banco.

Tabela	Garantia
members	Usuário acessa apenas membros do próprio <code>client_id</code> ; isolamento enforced com <code>WITH CHECK</code>
meetings	Conselheiro não pode criar/editar/excluir reuniões via chamada direta à API; role verificada no JWT
audit_logs	<code>UPDATE</code> e <code>DELETE</code> bloqueados por RLS em nível de banco — logs são tecnicamente imutáveis
server_audit_logs	Leitura restrita exclusivamente à role SuperAdmin via JWT

3. API E EDGE FUNCTIONS

Função	Controles Aplicados
create-user	JWT obrigatório + verificação de papel (Administrador/SuperAdmin) + isolamento por <code>client_id</code>
send-invitation	JWT obrigatório + escaping HTML em todos os campos + CORS restrito por whitelist
send-minute-notification	JWT obrigatório + escaping HTML em todos os campos + CORS restrito por whitelist
send-calendar-invites	JWT obrigatório + CORS restrito por whitelist. Gera convites de calendário (<code>.ics</code>) no servidor
analyze-minutes	JWT obrigatório + chave Gemini armazenada como secret do servidor (ausente no bundle JS)
clicksign-flow / clicksign-check	Verificação de Bearer token + comunicação servidor-a-servidor com o ClickSign (token de API como secret)
clicksign-webhook	Endpoint de retorno do ClickSign — autenticado por assinatura HMAC-SHA256 (cabeçalho <code>Content-Hmac</code>); rejeita requisições sem assinatura válida

4. SUB-PROCESSADORES E TRATAMENTO DE DADOS (LGPD)

O GovCorp utiliza os seguintes provedores para operar. Nenhum dado de conselho é compartilhado com terceiros além dos listados, e cada um atua estritamente na finalidade indicada.

Provedor	Finalidade	Dados tratados
Supabase	Banco de dados, autenticação e	Todos os dados da aplicação (isolados por <code>client_id</code>)

Provedor	Finalidade	Dados tratados
	armazenamento	
Vercel	Hospedagem do front-end	Não armazena dados de negócio — entrega de interface estática via HTTPS/CDN
Resend	Envio de e-mails (convocações, atas, convites)	Nome, e-mail e dados da reunião contidos na mensagem
ClickSign	Assinatura digital de atas (opcional, por cliente)	Documento da ata + nome/e-mail dos signatários. Ativado individualmente via <code>clicksign_enabled</code>
Google (Gemini)	Análise opcional de atas por IA	Texto da ata enviado sob demanda; chave de API mantida como secret do servidor

5. PROTEÇÃO DE DADOS E SECRETS

✓ Chaves de API externas	Gemini e Resend armazenadas como Supabase Secrets no servidor. Ausentes no bundle JavaScript entregue ao browser.
✓ Arquivos e atas	Acesso via Signed URLs com expiração de 7 dias — sem links públicos permanentes.
✓ Injeção de HTML	<code>escapeHtml()</code> e <code>safeUrl()</code> aplicados em todos os campos de entrada do usuário renderizados nos e-mails.
✓ CORS	Whitelist de origens explícita em todas as Edge Functions. Nenhum endpoint aceita <code>*</code> .
✓ Senhas	Nunca armazenadas em texto plano. Hash gerenciado pelo Supabase Auth (bcrypt).
✓ <code>process_audit_log</code>	SECURITY DEFINER com <code>SET search_path = ''</code> e EXECUTE revogado de PUBLIC, anon e authenticated. Executada exclusivamente por triggers internos — não exposta via API REST. Zero warnings no linter do Supabase.
✓ Webhook ClickSign	Assinatura HMAC-SHA256 validada em todas as requisições (cabeçalho <code>Content-Hmac</code>) contra secret do servidor. Requisições sem assinatura válida são rejeitadas (401) — <i>fail-closed</i> .

6. TRILHA DE AUDITORIA

Todas as ações relevantes — login, criação de reunião, upload de ata, cadastro de membros, convocações — são registradas automaticamente em `audit_logs`. As políticas RLS garantem que registros existentes

não possam ser alterados ou removidos por nenhum usuário, incluindo administradores. A tabela aceita apenas INSERT por usuários autenticados.

7. TRANSPARÊNCIA — O QUE NÃO ESTÁ IMPLEMENTADO

⚠ ITENS FORA DE ESCOPO DESTA FASE

Esta seção existe por transparência técnica. Equipes de segurança valorizam saber exatamente o que foi e o que não foi endereçado.

Item	Status
MFA obrigatório	Não configurado — usuários podem ativar voluntariamente no Supabase
Pen test por terceiro	Não realizado nesta fase; planejado para antes do lançamento geral
Rate limiting customizado	Depende dos limites padrão do Supabase (30 req/5min por IP)
Cabeçalhos CSP / HSTS	Gerenciados pela Vercel via HTTPS enforçado — fora do escopo da aplicação
IP allowlist	Não configurado

8. INFRAESTRUTURA E AMBIENTES

Camada	Tecnologia	Observação
Front-end	React + TypeScript	Deploy via Vercel — HTTPS enforçado, CDN global
Back-end	Supabase (PostgreSQL)	Dois projetos isolados: produção e homologação
Autenticação	Supabase Auth	JWT com expiração de 1 hora, refresh token rotation ativo
Funções serverless	Deno Edge Functions	Isoladas por função, sem estado compartilhado
Armazenamento	Supabase Storage	Acesso via Signed URLs com TTL de 7 dias
E-mail transacional	Resend API	Chave armazenada como secret do servidor

Camada	Tecnologia	Observação
Assinatura digital	ClickSign API	Opcional por cliente. Token como secret; retorno via webhook autenticado por HMAC